Universidad del Desarrollo
Seguridad y Protección de Datos – Proyecto Integrador

Actividad N°7

Trazabilidad y plan de respuesta a incidentes

Caso 1: NortiShop (comercio electrónico)

Grupo 7
Integrantes: Ignacia Castillo, Milan Kurte, Francisco Polo
Fecha: 13/11/2026
Repositorio: github.com/m1lvn/nortishop-seguridad (rama actividad7)

Índice

1. Introducción.....3
1.1 Alcance y normativa aplicable.....3
1.2 Punto de partida y qué se agregó.....3
2. Eventos auditados y campos del registro.....4
2.1 Qué se audita.....4
2.2 Campos de cada registro.....5
2.3 El catálogo como control.....6
3. Implementación del registro de auditoría.....6
3.1 Un solo punto de escritura.....6
3.2 Accesos que fallan después de autorizarse.....6
3.3 Operaciones que antes no dejaban registro.....7
4. Protección de los registros.....7
4.1 Acceso restringido.....7
4.2 Integridad.....9
4.3 Plazos de conservación.....10
5. Alertas de acceso anómalo.....10
6. Plan de respuesta a incidentes.....12
6.1 Criterios.....12
6.2 Responsables.....13
6.3 Fases.....13
6.4 Contenido de la notificación.....14
7. Simulacro de incidente.....15
7.1 Escenario.....15
7.2 Detección.....15
7.3 Respuesta.....16
7.4 Reconstrucción con la bitácora.....17
7.5 ¿Los registros permiten reconstruir lo ocurrido?.....19
7.6 Evaluación, notificación y cierre.....19
7.7 La bitácora no tiene los datos y no se puede recortar.....20
8. Pruebas.....21
9. Limitaciones.....21
10. Referencias.....22
Anexo A. Cumplimiento de la pauta.....23

1. Introducción

1.1 Alcance y normativa aplicable

Esta actividad trata la trazabilidad de NortiShop y su respuesta a incidentes. Parte del inventario de datos personales (informe de inventario y clasificación), que dice qué datos existen, dónde están y qué tan sensibles son, y de los controles ya implementados: cifrado y tokenización (Actividad 2), roles y seudonimización (Actividad 4), la bitácora encadenada, la detección y las herramientas de incidentes (Actividad 5) y los mecanismos de derechos (Actividad 6).

El marco es la Ley 19.628 modificada por la Ley 21.719. El artículo 14 quinquies obliga a adoptar medidas de seguridad apropiadas al riesgo, a verificarlas regularmente y, ante un incidente, a poder **demostrar** que existían y funcionaban: la bitácora es la prueba de eso. El artículo 14 sexies obliga a reportar a la Agencia, por los medios más expeditos y sin dilaciones indebidas, las vulneraciones que generen un riesgo razonable para los titulares; a **registrar** esas comunicaciones con la naturaleza de la vulneración, sus efectos, las categorías de datos, el número aproximado de titulares y las medidas adoptadas; y a notificar también a los titulares cuando se trate de datos sensibles, de menores de 14 años o relativos a obligaciones económicas, financieras, bancarias o comerciales. El artículo 15 bis obliga a los encargados (por ejemplo, la pasarela de pago) a avisar al responsable de cualquier vulneración. La Ley 21.663, Marco de Ciberseguridad, no aplica directamente a una tienda en línea, pero sí a la pasarela de pago como servicio esencial; el plan lo considera.

Las modificaciones de la Ley 21.719 rigen desde el 1 de diciembre de 2026 según su texto vigente. Como se indicó en las actividades anteriores, el proyecto del boletín N° 18.623-07 propone postergar esa fecha; mientras no sea ley, diseñamos para la fecha vigente.

1.2 Punto de partida y qué se agregó

La Actividad 5 ya tenía una bitácora con cadena HMAC, ocho reglas de detección y las herramientas de contención. Antes de agregar nada revisamos qué faltaba para cumplir cada punto de la pauta y si la bitácora realmente permitía reconstruir un incidente. Encontramos cinco problemas concretos: (1) no existía una lista cerrada de eventos, así que nada impedía que un desarrollador escribiera un dato personal en el detalle; (2) las compras de invitados, la retención y los cambios de estado de los pedidos no dejaban registro; (3) el decorador registraba "permitido" antes de ejecutar la operación, y si la regla de negocio la negaba después (por ejemplo, la dirección de un pedido ya entregado) la bitácora decía que el acceso se había concedido; (4) el administrador, cuyas propias acciones quedan en la bitácora, podía leerla completa; y (5) borrar las últimas filas no rompía la cadena, porque lo que queda sigue siendo una cadena válida.

Tabla 1. Cambios de la Actividad 7 respecto de la Actividad 5.

Pauta	Antes (Actividad 5)	Ahora (Actividad 7)
1. Eventos y campos	Lista de categorías en el informe; cualquier código se aceptaba	`catalogo_eventos.py`: 74 eventos con categoría, recurso y claves permitidas del detalle; un código no catalogado se rechaza

Pauta	Antes (Actividad 5)	Ahora (Actividad 7)
2. Registro sin datos	Compras de invitados, retención y estado de pedidos sin registro; fallas después de autorizar invisibles	Eventos `pedido.crear`, `pedido.estado`, `retencion.aplicar`, `analitica.guardar`; evento de falla con `tras=<id>`; un detalle con datos se reemplaza por `detalle_rechazado`
3. Protección y plazo	Administrador y seguridad leían todo; sin motivo; plazo solo para la bitácora	Solo seguridad lee, con motivo obligatorio; el administrador ve un resumen; anclas externas; plazos para bitácora, alertas, evidencia e incidentes
4. Alertas	8 reglas genéricas; ventanas medidas desde "ahora"	4 reglas propias de NortiShop; ventanas desde la fecha del evento; aviso inmediato a la guardia
5. Plan	Fases y responsables	Criterios de activación y severidad, tiempos objetivo, guardia 24/7, contenido de la notificación por destinatario y registro del art. 14 sexies
6. Simulacro	Incidente de prueba en `evidencia_act5.py`	`simulacro_act7.py` con verdad de terreno y `trazabilidad.reconstruir`; compara ambas

2. Eventos auditados y campos del registro

2.1 Qué se audita

Auditamos toda operación que crea, lee, modifica, exporta o elimina un dato personal, y toda operación que cambia quién puede hacerlo. El criterio sale del inventario: cada categoría de dato del inventario tiene al menos un evento que registra su lectura y uno que registra su creación o cambio. Se registran tanto los accesos permitidos como los denegados, porque varios intentos denegados seguidos son una señal de abuso.

Tabla 2. Eventos por categoría (lista completa en evidencia/ev_act7_catalogo.txt).

Categoría	Eventos	Por qué
autenticacion	`auth.login` (éxito, fallido con motivo), `sesion.crear`, `sesion.cerrar`	Toma de cuentas y fuerza bruta; red de origen de cada sesión
creacion	`cuenta.registrar`, `pedido.crear` (con cuenta o invitado)	Nacen datos personales: correo, teléfono, dirección
acceso	`contacto.cliente.leer`, `contacto.invitado.leer`, `despacho.direccion.leer`, `cuenta.propia.leer`, `pedidos.propios.leer`, `encuesta.destinatarios`	Cada vez que la aplicación descifra un dato para una persona
exportacion	`derechos.exportar`	Sale una copia completa de los datos de un titular
modificacion	`derechos.rectificar`, `pedido.estado`, `pedidos.estado.actualizar`	Cambio del dato o de su uso (despacho)
supresion	`derechos.suprimir`, `cuenta.suprimir`, `cuenta.eliminar`, `retencion.aplicar`	Prueba de que se borró lo que se debía

Categoría	Eventos	Por qué
tratamiento	`analitica.guardar`	Uso con consentimiento: queda si se guardó o por qué no
consentimiento	`consentimiento.otorgar`, `revocar`, `texto.publicar`, alta y baja del boletín	Prueba de licitud
derechos	`derechos.solicitar`, `verificar_identidad`, `reenviar_codigo`, `prorrogar`, `oponer`, `bloquear`	Plazos y verificación del art. 11
administracion	`roles.crear_cuenta`, `roles.restablecer_clave`, `auditoria.consultar`, `auditoria.purgar`, `auditoria.anclar`	Quién cambió privilegios y quién miró la bitácora
seguridad	`alertas.*`, `incidentes.*` (incluye `reconstruir`), `contencion.*`	Trazabilidad de la propia respuesta

2.2 Campos de cada registro

Tabla 3. Campos de la tabla auditoria.

Campo	Contenido	Ejemplo del simulacro
id	Correlativo; da el orden real de los eventos	102
fecha	UTC, del reloj único del sistema (`reloj.py`)	2026-11-13 06:17:40
actor_tipo, actor_id	Quién actuó, por id interno (vacío si es el sistema o alguien sin sesión)	personal:2
rol	Rol con el que actuó en ese momento	soporte
permiso	Código de la operación (debe estar en el catálogo)	contacto.cliente.leer
categoria	Sale del catálogo, no del código que llama	acceso
recurso	Id o código del objeto; nunca el dato. Solo letras, números y `_.,:-`	999
resultado	permitido, denegado, exito o fallido (CHECK)	denegado
canal	web, api o sistema	web
origen	Red de la IP (/24 en IPv4, /48 en IPv6), no la IP	181.43.77.0/24
detalle	Solo claves del catálogo con valores cortos, o motivos de una lista	tras=102 motivo=regla_negocio
hash_previo, hash	HMAC-SHA256 encadenado con una llave que no está en la base	f2d4d7bc…

Lo que **no** se registra: contraseñas (ni la que se ingresó mal), códigos de verificación, tokens de sesión o de la pasarela, llaves, la IP completa y ningún valor de un dato personal (correo, nombre, teléfono, dirección, productos). Un login fallido con un correo que no existe se registra sin el correo, porque podría ser el de una persona real mal escrito. Con los ids basta para reconstruir: el rol seguridad puede cruzarlos con la base cuando lo necesita, y esa consulta también queda registrada.

2.3 El catálogo como control

`catalogo_eventos.py` define cada evento con su categoría, qué se guarda como recurso y qué claves admite el detalle. Además, por cada permiso de la matriz de roles existe un evento de control de acceso (permitido o denegado). En total son 74 eventos. `registrar_evento` aplica tres reglas:

- Un código que no está en el catálogo lanza un error: es un error de programación, y las pruebas lo detectan antes de llegar a producción (prueba E01).
- El detalle se divide en partes. Cada parte debe ser `clave=valor` con una clave permitida para ese evento y un valor de hasta 200 caracteres sin espacios ni `@`, o un motivo de la lista del evento. Si no cumple, el evento se guarda igual, pero con el detalle `detalle_rechazado`: no se pierde la traza y el dato no llega a la bitácora (prueba E02).
- El recurso debe ser un id o un código. Un correo usado como recurso se reemplaza por `recurso_rechazado`.

Con esto, la regla "no guardar los datos" deja de depender de que cada desarrollador la recuerde: un texto libre, un correo o una dirección no tienen forma de pasar el filtro.

3. Implementación del registro de auditoría

3.1 Un solo punto de escritura

Todo evento pasa por `auditoria.registrar_evento`, que valida contra el catálogo, toma el canal y la red de origen del contexto de la petición, calcula el HMAC encadenado dentro de una transacción `BEGIN IMMEDIATE` (dos procesos no pueden encadenar al mismo eslabón) y, al final, entrega el evento a las reglas de detección. Los accesos a datos se registran en `@requiere_permiso`, el único punto de control de acceso, así que ninguna función que descifre datos queda sin registro.

3.2 Accesos que fallan después de autorizarse

El decorador registra "permitido" antes de ejecutar la operación, para que quede rastro aunque la función falle a mitad de camino. Pero algunas reglas de negocio se evalúan dentro de la función: logística no puede ver la dirección de un pedido ya entregado, y soporte no puede consultar a un cliente con bloqueo vigente. En la Actividad 5 esos casos quedaban como "permitido", y una reconstrucción habría contado accesos que nunca entregaron datos. Ahora, si la operación lanza un error, el decorador agrega un segundo evento con el resultado real y una referencia al primero:

```
102 | 03:17:40 | personal:2 | contacto.cliente.leer | 999 | permitido |
103 | 03:17:40 | personal:2 | contacto.cliente.leer | 999 | denegado  | tras=102
      motivo=regla_negocio
```

Figura 1. *Un acceso autorizado por el rol que la función negó después (cliente inexistente). La reconstrucción lo cuenta como denegado.*

3.3 Operaciones que antes no dejaban registro

Tabla 4. Eventos nuevos sobre datos personales.

Evento	Cuándo	Recurso y detalle
`pedido.crear`	Compra con cuenta o como invitado; la compra de invitado crea su correo, teléfono y dirección sin que exista una cuenta	Id del pedido; `origen=invitado|cuenta`; si la pasarela rechaza, `fallido` con `pago_rechazado`
`pedido.estado`	Logística cambia el estado de un pedido	Id del pedido; `estado=despachado`
`retencion.aplicar`	Se borran dirección y contacto de pedidos antiguos y se eliminan los que terminaron su bloqueo legal	`pedidos_anonimizados=N pedidos_eliminados=M`
`analitica.guardar`	Se guarda el comportamiento de compra bajo seudónimo, o se omite	Id del cliente (no el seudónimo); `sin_consentimiento` o `tratamiento_suspendido` si se omitió
`roles.restablecer_clave`	El administrador fija una contraseña nueva a una cuenta del personal comprometida	`personal:ID`; `sesiones=N` revocadas; nunca la contraseña
`alertas.estado`, `alertas.avisar`	Seguridad analiza o descarta una alerta; se avisa a la guardia	Id de la alerta; estado o destino
`auditoria.consultar`, `auditoria.anclar`	Lectura filtrada de la bitácora; copia del último hash	Motivo y nombres de los filtros; último id
`incidentes.reconstruir`, `incidentes.purgar_evidencia`	Reconstrucción de un incidente; eliminación de copias vencidas	Actor, eventos y recursos; carpetas eliminadas

La prueba del simulacro (sección 7.7, Figura 11) busca los 130 datos personales ficticios que se crearon (nombres, correos, teléfonos y direcciones) en los 158 eventos de la bitácora y no encuentra ninguno; tampoco la contraseña robada ni la IP completa del atacante.

4. Protección de los registros

4.1 Acceso restringido

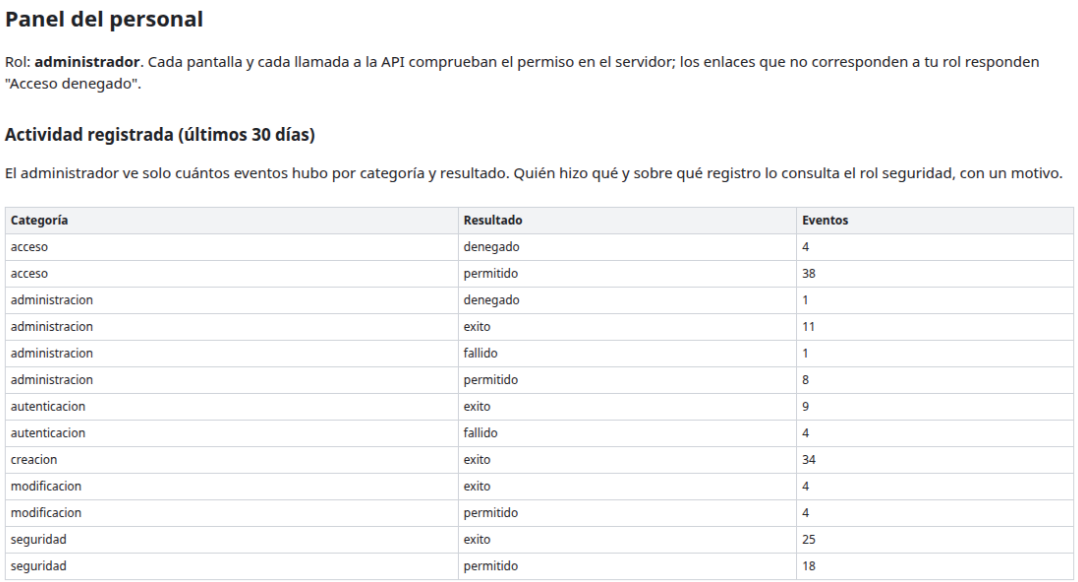
Quien puede leer la bitácora puede saber qué cliente llamó a soporte, a qué hora y desde qué red. Por eso el acceso se trata igual que el acceso a un dato personal: mínimo privilegio, finalidad declarada y registro de cada consulta.

Tabla 5. Quién puede hacer qué con los registros.

Rol	Puede	No puede
seguridad	Consultar la bitácora con filtros (actor, recurso, operación, fechas) declarando un motivo; verificar la integridad; reconstruir un incidente; purgar lo vencido	Modificar o borrar registros recientes (no existe la función y los triggers lo impiden)

Rol	Puede	No puede
administrador	Ver un resumen: cantidad de eventos por categoría y resultado en los últimos 30 días (Figura 2)	Ver quién hizo qué ni sobre qué registro: sus propias acciones (crear cuentas, restablecer contraseñas, retención) están en la bitácora
privacidad, soporte, logística, marketing, clientes	—	Leer la bitácora o su resumen (403)

Motivo obligatorio. `trazabilidad.consultar` exige un motivo que exista: un incidente (`INC-…`), una alerta (`ALERTA-N`) o uno de tres motivos generales (`revision_periodica`, `requerimiento_agencia`, `reclamo_titular`). Sin motivo, la web muestra solo el formulario y la API responde 400. La consulta queda registrada con el motivo, los **nombres** de los filtros y la cantidad de filas, pero no los valores filtrados: `motivo=ALERTA-4 filtros=actor,desde filas=38`. Así, una revisión posterior puede preguntar por qué alguien consultó la bitácora y si la consulta correspondía al motivo.



Panel del personal

Rol: **administrador**. Cada pantalla y cada llamada a la API comprueban el permiso en el servidor; los enlaces que no corresponden a tu rol responden "Acceso denegado".

Actividad registrada (últimos 30 días)

El administrador ve solo cuántos eventos hubo por categoría y resultado. Quién hizo qué y sobre qué registro lo consulta el rol seguridad, con un motivo.

Categoría	Resultado	Eventos
acceso	denegado	4
acceso	permitido	38
administracion	denegado	1
administracion	exito	11
administracion	fallido	1
administracion	permitido	8
autenticacion	exito	9
autenticacion	fallido	4
creacion	exito	34
modificacion	exito	4
modificacion	permitido	4
seguridad	exito	25
seguridad	permitido	18

Figura 2. *Panel del administrador: solo el resumen por categoría y resultado, sin actores, recursos ni detalle.*

38 eventos

#	Fecha (UTC)	Actor	Rol	Operación	Categoría	Recurso	Resultado	Canal	Origen	Detalle
66	2026-11-13 06:07:12	—	—	auth.login	autenticacion	personal:2	fallido	web	181.43.77.0/24	clave_incorrecta
67	2026-11-13 06:07:37	—	—	auth.login	autenticacion	personal:2	fallido	web	181.43.77.0/24	clave_incorrecta
68	2026-11-13 06:08:02	—	—	auth.login	autenticacion	personal:2	exito	web	181.43.77.0/24	
70	2026-11-13 06:08:20	personal:2	soporte	contacto.cliente.leer	acceso	1	permitido	web	181.43.77.0/24	
72	2026-11-13 06:08:38	personal:2	soporte	contacto.cliente.leer	acceso	2	permitido	web	181.43.77.0/24	
73	2026-11-13 06:08:56	personal:2	soporte	contacto.cliente.leer	acceso	3	permitido	web	181.43.77.0/24	
74	2026-11-13 06:09:14	personal:2	soporte	contacto.cliente.leer	acceso	4	permitido	web	181.43.77.0/24	
75	2026-11-13 06:09:32	personal:2	soporte	contacto.cliente.leer	acceso	5	permitido	web	181.43.77.0/24	
76	2026-11-13 06:09:50	personal:2	soporte	contacto.cliente.leer	acceso	6	permitido	web	181.43.77.0/24	
77	2026-11-13 06:10:08	personal:2	soporte	contacto.cliente.leer	acceso	7	permitido	web	181.43.77.0/24	
78	2026-11-13 06:10:26	personal:2	soporte	contacto.cliente.leer	acceso	8	permitido	web	181.43.77.0/24	
81	2026-11-13 06:10:44	personal:2	soporte	contacto.cliente.leer	acceso	9	permitido	web	181.43.77.0/24	
82	2026-11-13 06:11:02	personal:2	soporte	contacto.cliente.leer	acceso	10	permitido	web	181.43.77.0/24	
83	2026-11-13 06:11:20	personal:2	soporte	contacto.cliente.leer	acceso	11	permitido	web	181.43.77.0/24	
84	2026-11-13 06:11:38	personal:2	soporte	contacto.cliente.leer	acceso	12	permitido	web	181.43.77.0/24	
85	2026-11-13 06:11:56	personal:2	soporte	contacto.cliente.leer	acceso	13	permitido	web	181.43.77.0/24	
86	2026-11-13 06:12:14	personal:2	soporte	contacto.cliente.leer	acceso	14	permitido	web	181.43.77.0/24	
87	2026-11-13 06:12:32	personal:2	soporte	contacto.cliente.leer	acceso	15	permitido	web	181.43.77.0/24	
88	2026-11-13 06:12:50	personal:2	soporte	contacto.cliente.leer	acceso	16	permitido	web	181.43.77.0/24	
89	2026-11-13 06:13:08	personal:2	soporte	contacto.cliente.leer	acceso	17	permitido	web	181.43.77.0/24	
90	2026-11-13 06:13:26	personal:2	soporte	contacto.cliente.leer	acceso	18	permitido	web	181.43.77.0/24	
91	2026-11-13 06:13:44	personal:2	soporte	contacto.cliente.leer	acceso	19	permitido	web	181.43.77.0/24	
92	2026-11-13 06:14:02	personal:2	soporte	contacto.cliente.leer	acceso	20	permitido	web	181.43.77.0/24	
93	2026-11-13 06:14:20	personal:2	soporte	contacto.cliente.leer	acceso	21	permitido	web	181.43.77.0/24	
94	2026-11-13 06:14:38	personal:2	soporte	contacto.cliente.leer	acceso	22	permitido	web	181.43.77.0/24	
95	2026-11-13 06:14:56	personal:2	soporte	contacto.cliente.leer	acceso	23	permitido	web	181.43.77.0/24	
96	2026-11-13 06:15:14	personal:2	soporte	contacto.cliente.leer	acceso	24	permitido	web	181.43.77.0/24	
97	2026-11-13 06:15:32	personal:2	soporte	contacto.cliente.leer	acceso	25	permitido	web	181.43.77.0/24	
98	2026-11-13 06:15:50	personal:2	soporte	contacto.cliente.leer	acceso	26	permitido	web	181.43.77.0/24	
99	2026-11-13 06:16:20	personal:2	soporte	despacho.direccion.leer	acceso	1	denegado	web	181.43.77.0/24	
100	2026-11-13 06:16:50	personal:2	soporte	despacho.direccion.leer	acceso	2	denegado	web	181.43.77.0/24	
101	2026-11-13 06:17:20	personal:2	soporte	auditoria.leer	administracion	—	denegado	web	181.43.77.0/24	
102	2026-11-13 06:17:40	personal:2	soporte	contacto.cliente.leer	acceso	999	permitido	web	181.43.77.0/24	
103	2026-11-13 06:17:40	personal:2	soporte	contacto.cliente.leer	acceso	999	denegado	web	181.43.77.0/24	tras=102 motivo=regla_negocio
104	2026-11-13 06:18:02	personal:2	soporte	contacto.invitado.leer	acceso	3	permitido	web	181.43.77.0/24	
105	2026-11-13 06:18:24	personal:2	soporte	contacto.invitado.leer	acceso	4	permitido	web	181.43.77.0/24	
106	2026-11-13 06:18:46	personal:2	soporte	contacto.invitado.leer	acceso	5	permitido	web	181.43.77.0/24	
109	2026-11-13 06:19:08	personal:2	soporte	contacto.invitado.leer	acceso	6	permitido	web	181.43.77.0/24	

Figura 3. *Consulta de la bitácora por el rol seguridad, con el incidente como motivo, filtrada por actor y ventana de tiempo (extracto).*

4.2 Integridad

- **Inmutabilidad en la base:** el trigger `auditoria_sin_update` rechaza toda modificación y `auditoria_sin_delete` solo permite borrar filas de más de 2 años.
- **Cadena HMAC:** cada fila guarda el HMAC de sus campos y del hash anterior, con la llave `NORTISHOP_LLAVE_AUDITORIA`, que no está en la base. Quien quite los triggers puede cambiar una fila, pero no recalcular su HMAC: `verificar_cadena` indica la primera fila que no cuadra.
- **Anclas externas (nuevo):** borrar las últimas filas no rompe la cadena, porque lo que queda sigue siendo válido. Una tarea programada ejecuta `auditoria.anclar` cada hora y agrega el último id y hash a un archivo de solo agregar fuera de la base (en producción, en otro servidor). `verificar_anclas` comprueba que cada ancla siga en la bitácora con el mismo hash, salvo las que una purga registrada eliminó por plazo. El simulacro lo demuestra: en una copia de la base se borran

todas las filas desde el ataque; la cadena sigue "correcta", pero el ancla de las 04:00 ya no existe y se genera una alerta crítica (sección 7.7, prueba P03).

- **Archivo:** la base se crea con permisos 600 y el archivo de anclas también.

4.3 Plazos de conservación

Un registro que se guarda para siempre es un riesgo: si se filtra, revela años de actividad. Uno que se borra pronto no sirve para investigar un incidente que se descubre tarde ni para responder a la Agencia. Fijamos un plazo por tipo de registro:

Tabla 6. Plazos de conservación de los registros de trazabilidad.

Registro	Plazo	Cómo se aplica	Fundamento
Bitácora de auditoría	2 años	Trigger + `purgar_auditoria` (rol seguridad), que deja constancia del último hash eliminado	Investigar incidentes detectados tarde y responder reclamos (art. 11: 30 días hábiles desde la respuesta)
Anclas externas	2 años	Igual que la bitácora	Solo sirven mientras exista lo que anclan
Alertas descartadas (falsos positivos)	2 años	`purgar_auditoria` las borra junto con la bitácora vencida	Ajustar las reglas con la historia de falsos positivos
Alertas escaladas y registro de incidentes	5 años desde el cierre	No se borran desde la aplicación	Registro exigido por el art. 14 sexies inc. 2 y prueba de las medidas (art. 14 quinquies)
Copia de la base preservada como evidencia	1 año desde el cierre	`incidentes.purgar_evidencia`	Contiene los datos (cifrados) de toda la base: no puede quedar indefinidamente
Logs de la aplicación	90 días	Rotación del sistema operativo	Solo diagnóstico; pasan por el filtro de datos personales

Los 5 años del registro de incidentes son una decisión nuestra: la ley exige registrar las comunicaciones pero no fija un plazo. Elegimos un plazo largo porque ese registro casi no tiene datos personales (categorías y cantidades, no los datos) y es lo que permite demostrar cómo se respondió.

Eliminación segura. Toda conexión activa `PRAGMA secure_delete`, así que lo purgado se sobrescribe y no queda en páginas libres del archivo. Las copias de evidencia tienen permisos 0400; la purga los cambia antes de borrar la carpeta.

5. Alertas de acceso anómalo

Las reglas de la Actividad 5 (fuerza bruta, relleno de credenciales, exportación anómala, consulta masiva, etc.) son genéricas: sirven para cualquier sistema. Para esta actividad diseñamos cuatro reglas a partir de cómo trabaja NortiShop: quién necesita qué dato, cuándo y desde dónde. El caso que más preocupa es el de un empleado legítimo, o alguien con sus credenciales, que usa permisos reales para extraer datos: ningún control de acceso lo detiene, porque el permiso existe.

Tabla 7. Alertas nuevas, propias de NortiShop.

Regla	Qué la dispara	Por qué es anómalo en NortiShop	Severidad
`fuera_de_horario`	Una persona del personal descifra un contacto o una dirección (`contacto.*.leer`, `despacho.direccion.leer`) fuera de 08:00-21:00 (hora de Chile) o un domingo	Soporte y logística atienden en ese horario; nadie necesita el teléfono de un cliente a las 03:00	media
`red_nueva_personal`	Inicio de sesión exitoso de una cuenta del personal desde una red (/24) que no usó en los últimos 90 días. Solo si la cuenta ya tiene historia	El personal trabaja desde la oficina o su VPN; una red nueva sugiere credenciales robadas	media; alta si la cuenta es administrador o seguridad
`lectura_secuencial`	Una persona consulta 8 o más registros de ids consecutivos con la misma operación en 15 minutos	Un caso de soporte llega por un cliente concreto: los ids que se consultan son dispersos. Recorrer 1, 2, 3… es extracción, aunque el volumen sea bajo	alta
`direcciones_historicas`	Logística pide 3 o más direcciones de pedidos que ya no tienen envío activo (la regla de negocio las niega) en 1 hora	La dirección solo se necesita para despachar; buscar dónde vivían clientes pasados no tiene relación con el trabajo	media

Las reglas se evalúan en cada evento. Dos cambios hacen que sean confiables:

- **Ventanas desde la fecha del evento.** En la Actividad 5 las ventanas se medían con `datetime('now')`. Si los eventos se procesan con atraso, o se reproducen para una prueba, la ventana queda mal. Ahora se miden hacia atrás desde la fecha del evento, que viene de un reloj único (`reloj.py`). Eso también permite reproducir el simulacro a las 03:07 (prueba L06).
- **Aviso inmediato a la guardia.** El primer ensayo del simulacro mostró que la alerta alta de las 03:10 habría quedado en el panel hasta que alguien llegara a las 08:30: cinco horas con el atacante dentro. Ahora toda alerta alta o crítica envía un aviso a la guardia de seguridad (correo simulado; en producción, correo y SMS) con el número de alerta, la regla y la severidad, sin la descripción, que tiene ids de cuentas (prueba L05).

Falsos positivos. Un turno extraordinario dispara `fuera_de_horario` y un viaje dispara `red_nueva_personal`. Por eso tienen severidad media y no bloquean nada: seguridad las revisa y las descarta con un clic, y la decisión queda registrada (`alertas.estado`). Una alerta no duplica otra abierta de la misma regla sobre la misma cuenta en la última hora. Las dos reglas de severidad alta (`lectura_secuencial` y `consulta_masiva`) describen patrones que el trabajo normal no produce.

Tabla 8. Reglas heredadas de la Actividad 5 (siguen activas).

Regla	Condición	Severidad
fuerza_bruta_cuenta	5 inicios de sesión fallidos sobre una cuenta en 15 minutos	media
relleno_credenciales	Fallos sobre 10 cuentas distintas en 10 minutos	alta
exportacion_anomala / cambio_correo_y_exportacion	3 exportaciones en 24 horas / cambio de correo y exportación en 24 horas	alta

Regla	Condición	Severidad
consulta_masiva	Una persona del personal descifra 30 registros en 1 hora	alta
denegaciones_repetidas	5 accesos denegados del mismo actor en 10 minutos	media
cambio_privilegios	Se crea una cuenta administrador o seguridad	media
integridad_auditoria	La cadena HMAC no cuadra o no coincide con un ancla externa	crítica

6. Plan de respuesta a incidentes

El plan se aplica a cualquier evento que comprometa o pueda comprometer la confidencialidad, integridad o disponibilidad de los datos personales de NortiShop, ya sea en sus sistemas o en los de un encargado (pasarela de pago, hosting, empresa de despacho). Sus herramientas están implementadas en `deteccion.py`, `incidentes.py` y `trazabilidad.py` y se usan desde el panel de seguridad.

6.1 Criterios

Alerta, evento sospechoso e incidente. Una alerta la genera una regla y no es un incidente. Seguridad la pasa a "en análisis" si no tiene una explicación evidente, consulta la bitácora con la alerta como motivo y decide. Hay **incidente** cuando existe evidencia de que datos personales se vieron o pudieron verse afectados: acceso por alguien no autorizado (aunque use credenciales válidas), alteración, pérdida o indisponibilidad. También se abre un incidente sin alerta cuando llega un reporte por los canales del plan: un cliente, un investigador, la pasarela (art. 15 bis) o el hallazgo de credenciales o llaves publicadas.

Tabla 9. Severidad del incidente.

Severidad	Criterio	Ejemplos en NortiShop	Tiempo objetivo de contención
baja	Intento sin acceso a datos	Fuerza bruta bloqueada; alerta de red nueva que resulta ser un viaje	Revisión en el día hábil
media	Acceso a datos de contacto de pocos titulares (menos de 10), o a una cuenta de cliente	Cuenta de cliente tomada; consulta indebida de un empleado a un conocido	4 horas
alta	Datos de muchos titulares, credenciales del personal comprometidas, historial de compras expuesto	El caso del simulacro: 30 contactos extraídos con una cuenta de soporte	1 hora desde el aviso
crítica	Base filtrada junto con las llaves, bitácora alterada, cuenta administrador o seguridad comprometida, datos de tarjetas o de la pasarela	Copia de la base y del `.env` publicada; alerta `integridad_auditoria`	Inmediata (se puede revocar todas las sesiones y suspender permisos)

Criterio de notificación (`incidentes.evaluar_notificacion`, art. 14 sexies):

- **A la Agencia:** cuando hay riesgo razonable para los titulares. Lo hay si quien accedió pudo **leer** los datos: los vio en claro a través de la aplicación (que descifra) o se llevó datos cifrados junto con las

llaves. Si solo obtuvo datos cifrados y las llaves no se comprometieron, el riesgo se considera no razonable, y la decisión se documenta igual. Las credenciales siempre implican riesgo.

- **A los titulares:** además, cuando se afectan datos sensibles, de menores de 14 años (NortiShop no los trata) o relativos a obligaciones económicas o comerciales: historial de compras, últimos dígitos de la tarjeta y tokens de pago. Si no fuera posible avisar a cada uno, se publica un aviso en un medio de circulación nacional.
- **Aviso voluntario:** cuando no es obligatorio, la delegada de protección de datos puede decidir avisar igual a los titulares si el riesgo para ellos es concreto (por ejemplo, phishing dirigido con los datos extraídos). Esa decisión se registra en las medidas del incidente.

6.2 Responsables

Tabla 10. Responsables del plan (en la empresa real serían cargos; aquí, los integrantes del grupo).

Responsable	Función en el plan	Rol en el sistema	Suplente
Milan Kurte	Responsable de seguridad y coordinador del incidente: clasifica, decide la contención, preserva la evidencia, reconstruye y cierra. Encabeza la guardia.	seguridad	Francisco Polo
Francisco Polo	Desarrollo y administración: restablece contraseñas, rota llaves, corrige vulnerabilidades, restaura respaldos y despliega.	administrador (y acceso al servidor)	Milan Kurte
Ignacia Castillo	Delegada de protección de datos y comunicación: evalúa el riesgo para los titulares, redacta y autoriza las notificaciones a la Agencia y a los titulares, atiende consultas.	privacidad	Milan Kurte (solo redacción; la autorización espera a la delegada)
Guardia de seguridad (turno semanal)	Recibe los avisos de alertas altas y críticas las 24 horas, hace el análisis inicial y ejecuta la contención reversible sin esperar autorización.	seguridad	El siguiente del turno

Canales de reporte: internos, el panel de seguridad, los avisos a la guardia y el canal de seguridad del equipo; externos, privacidad@nortishop.cl (clientes y terceros) y seguridad@nortishop.cl (investigadores); proveedores, la obligación contractual de avisar (art. 15 bis) de la pasarela, el hosting y la empresa de despacho.

6.3 Fases

Tabla 11. Fases del plan y su apoyo en el sistema.

Fase	Qué se hace	Herramienta	Quién
1. Preparación	Roles y suplentes, guardia, canales, plantillas de notificación, revisión trimestral de reglas y permisos, simulacro semestral	Catálogo de eventos, reglas, anclas cada hora, `simulacro_act7.py`	Seguridad
2. Detección y análisis	Revisar la alerta; consultar la bitácora con la alerta como motivo; descartar o escalar a incidente; asignar severidad	Aviso a la guardia, `trazabilidad.consultar`, `registrar_incidente`	Guardia / seguridad

Fase	Qué se hace	Herramienta	Quién
3. Contención	Primero preservar la evidencia; luego cortar el acceso. Ante una posible toma de cuenta se contiene primero (es reversible) y se confirma después	`preservar_evidencia`, `deshabilitar_cuenta`, `revocar_sesiones`, `suspender_permiso`	Guardia / seguridad
4. Erradicación	Eliminar la causa: contraseña nueva, llaves rotadas, vulnerabilidad corregida	`restablecer_clave_personal`, `generar_llaves.py --rotar`, `rotar_llaves.py`	Administración
5. Recuperación	Restablecer el servicio solo cuando las comprobaciones pasan	`comprobar_recuperacion`, `habilitar_cuenta`, `reaplicar_supresiones` si se restaura un respaldo	Seguridad + administración
6. Notificación	Reconstruir el alcance, decidir, redactar, autorizar y enviar; registrar la comunicación	`reconstruir`, `registrar_evaluacion`, `borrador_notificacion`, `registrar_notificacion`	Delegada de protección de datos
7. Lecciones aprendidas	Causa raíz, medidas correctivas y ajuste de reglas; cierre	`cerrar_incidente` (exige lecciones, notificación resuelta, sin permisos suspendidos y bitácora íntegra)	Todos

Tiempos objetivo (decisión interna; la ley exige "sin dilaciones indebidas" y no fija horas): aviso a la guardia inmediato; acuse de una alerta alta o crítica en 15 minutos; contención según la Tabla 9; decisión de notificación dentro de 48 horas desde la detección; reporte a la Agencia dentro de 72 horas desde que se confirma el incidente, aunque la investigación siga abierta (se completa después con la misma referencia); aviso a los titulares junto con el reporte o inmediatamente después. Tomamos las 72 horas del Reglamento General de Protección de Datos europeo como referencia razonable de "sin dilaciones indebidas".

6.4 Contenido de la notificación

Tabla 12. Contenido mínimo de cada comunicación (art. 14 sexies).

Contenido	Agencia	Titulares	De dónde sale en el sistema
Qué ocurrió (naturaleza de la vulneración)	Sí	Sí, en lenguaje claro	Descripción del incidente
Fecha de detección y período en que ocurrió	Sí	Sí	`fecha_deteccion`; inicio y fin del acceso a datos de la reconstrucción
Categorías de datos afectados	Sí	Sí (identificar los datos)	`categorias_datos` de la reconstrucción
Número aproximado de titulares	Sí	No	`titulares` de la reconstrucción
Posibles consecuencias (efectos)	Sí	Sí	Plantilla según las categorías
Medidas adoptadas y para evitar que se repita	Sí	Sí (medidas de mitigación)	Medidas registradas en cada fase

Contenido	Agencia	Titulares	De dónde sale en el sistema
Recomendaciones al titular	—	Sí	Plantilla (cambiar contraseñas, desconfiar de mensajes que pidan datos)
Contacto y código del incidente	Sí	Sí	privacidad@nortishop.cl + `INC-...`

El **registro** que exige el inciso segundo del art. 14 sexies es la tabla `incidentes`: naturaleza, efectos, categorías, número de titulares, medidas, decisión de notificar y fecha de la notificación, sin los datos personales. Se conserva 5 años (Tabla 6). Si el incidente ocurre en la pasarela, la pasarela reporta además al CSIRT Nacional según la Ley 21.663; NortiShop evalúa su propio deber de reportar a la Agencia con el aviso que la pasarela le entrega.

7. Simulacro de incidente

7.1 Escenario

`simulacro_act7.py` crea una tienda con 28 clientes, 6 compras de invitados y cuatro cuentas del personal en una base temporal con datos ficticios. Usa el reloj del sistema fijado en fechas concretas para que los horarios sean realistas. El escenario elegido es el que más nos preocupa: **credenciales legítimas en manos equivocadas**. Carla, agente de soporte, cayó en un correo de phishing. Su permiso `contacto.cliente.leer` es real, así que ningún control de acceso detiene al atacante: solo la trazabilidad y la detección pueden hacerlo.

1. **Miércoles 11/11:** se crea la tienda y el personal.
2. **Jueves 12/11 (línea base):** un día normal desde la red de la oficina (200.27.14.0/24): Carla atiende a 3 clientes, Luis (logística) despacha 4 pedidos. Las anclas se copian cada pocas horas.
3. **Viernes 13/11, 03:07:** alguien prueba dos variantes de la contraseña de Carla desde 181.43.77.201, acierta a la tercera y recorre los contactos de los clientes 1 a 26, cada 18 segundos. Intenta ver direcciones y la bitácora (no tiene permiso), consulta un id que no existe y luego los contactos de 4 compras de invitados.

El script guarda aparte lo que el atacante hizo de verdad (la "verdad de terreno"). Esa lista **no** se usa para la reconstrucción: solo para compararla al final.

7.2 Detección

Tabla 13. Alertas generadas por las reglas, sin intervención humana (evidencia/ev_act7_simulacro.txt).

#	Hora (Chile)	Regla	Severidad	Descripción
1	11/11 09:00	cambio_privilegios	media	Se creó una cuenta privilegiada (rol=seguridad)
2	13/11 03:08	red_nueva_personal	media	personal:2 (soporte) inició sesión desde la red 181.43.77.0/24, no usada en los últimos 90 días
3	13/11 03:08	fuera_de_horario	media	personal:2 (soporte) usó contacto.cliente.leer a las 03:08 (horario de atención 08:00-21:00)

#	Hora (Chile)	Regla	Severidad	Descripción
4	13/11 03:10	lectura_secuencial	alta	personal:2 (soporte) consultó 8 registros de ids consecutivos con contacto.cliente.leer en 15 minutos
5	13/11 03:18	consulta_masiva	alta	personal:2 (soporte) descifró 30 registros en 1 hora

Las cuatro reglas apuntan a la misma cuenta. `red_nueva_personal` y `fuera_de_horario` saltan en el primer minuto; `lectura_secuencial`, que es alta, a los dos minutos y medio, cuando el atacante iba en el cliente 8, y avisa a la guardia. `consulta_masiva`, la regla genérica de la Actividad 5, recién salta a las 03:18, con 30 registros ya extraídos. La alerta 1 es del miércoles (alta de la cuenta de seguridad) y se descarta en la revisión.

7.3 Respuesta

```
aviso a la guardia 03:10:26: [NortiShop] Alerta alta #4: lectura_secuencial
aviso a la guardia 03:18:46: [NortiShop] Alerta alta #5: consulta_masiva
03:24 verificar_integridad -> cadena ok=True filas=112 anclas=6 anclas_ok=True
alerta 1 (cambio_privilegios del miércoles): descartada, fue el alta planificada de seguridad
consultar sin un motivo válido                    -> ValueError
consultar(motivo=ALERTA-4, actor=personal:2, desde=13/11) -> 38 eventos
Cuatro reglas distintas sobre la misma cuenta: red nueva, fuera de horario, lectura secuencial y
    masiva.
Según el plan, una posible toma de cuenta se contiene primero (es reversible) y se confirma
    después.
03:27 incidente registrado: INC-20261113-5F3F (alerta 4 escalada)
03:28 evidencia preservada: sha256=177a421cdd91cd57ac482d4f... ancla de la bitácora id=124
03:29 contención: personal:2 deshabilitada y sus sesiones revocadas
03:29 la sesión del intruso intenta seguir leyendo contactos -> AccesoDenegado
08:10 se llama a Carla al iniciar su turno: no inició sesión en la noche y recordó un correo que
    le pidió
      "validar" su cuenta. Se confirma el uso indebido de sus credenciales (phishing).
```

Figura 4. *Respuesta de la guardia según el plan.*

La guardia contiene a las 03:29, 19 minutos después del aviso: preserva la evidencia **antes** de cambiar nada (copia de la base con su SHA-256 y el ancla de la bitácora), deshabilita la cuenta y revoca sus sesiones. Un último intento del intruso a las 03:29:40 ya es denegado. El atacante había terminado a las 03:19, así que la contención no evitó la extracción; sí evitó que siguiera, y el aviso hizo que la respuesta tomara minutos en vez de cinco horas.



Figura 5. *Panel de seguridad tras el incidente: las cuatro alertas del ataque vinculadas al incidente y la alerta del miércoles descartada. Capturas tomadas de otra ejecución del mismo simulacro, por eso el código del incidente difiere.*

7.4 Reconstrucción con la bitácora

`trazabilidad.reconstruir` recibe el incidente, el actor y una ventana de tiempo, y trabaja solo con la bitácora. Primero verifica la cadena y las anclas: si la bitácora no está íntegra, la reconstrucción lo informa y no sirve como prueba. Después arma la línea de tiempo y separa los inicios de sesión (con su red), los accesos **efectivos** (los permitidos que no fallaron después), los denegados y las demás operaciones; traduce cada operación a las categorías de datos que entrega y cuenta los titulares distintos, identificados solo por id interno (`cliente:7`, `invitado:pedido3`).

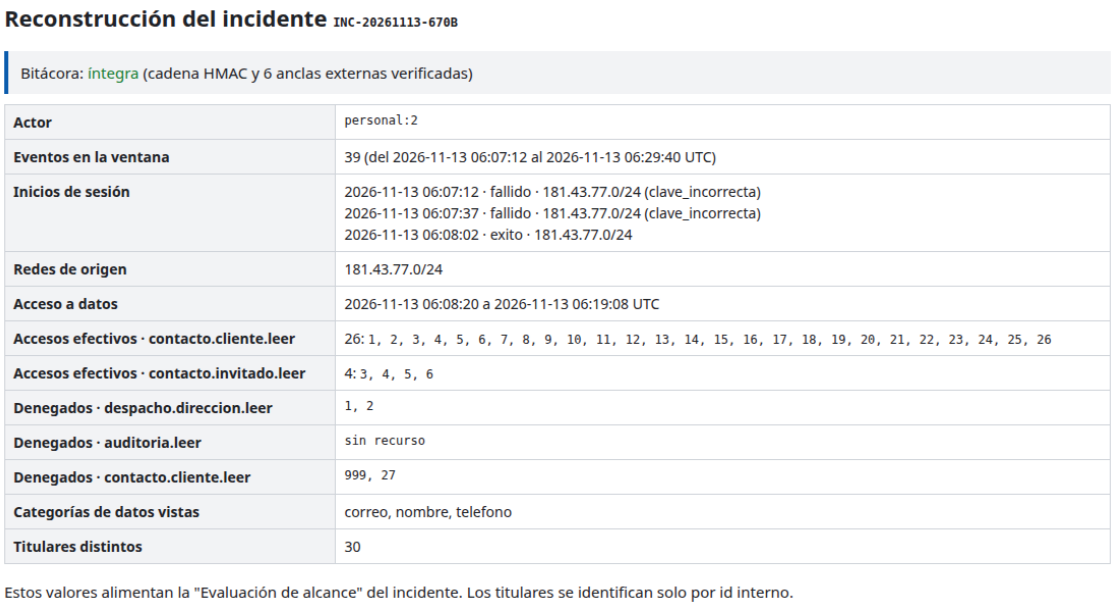
```
bitácora confiable (cadena y anclas): True
eventos del actor en la ventana: 39
inicios de sesión: 03:07:12 fallido 181.43.77.0/24 (clave_incorrecta); 03:07:37 fallido
    181.43.77.0/24 (clave_incorrecta); 03:08:02 exito 181.43.77.0/24
redes usadas: ['181.43.77.0/24']  (red habitual de Carla: 200.27.14.0/24)
acceso a datos entre 03:08:20 y 03:19:08 (hora de Chile)
accesos efectivos contacto.cliente.leer: 26 -> ['1', '2', '3', '4', '5', '6', '7', '8', '9', '10',
    '11', '12', '13', '14', '15', '16', '17', '18', '19', '20', '21', '22', '23', '24', '25',
    '26']
accesos efectivos contacto.invitado.leer: 4 -> ['3', '4', '5', '6']
denegados despacho.direccion.leer: ['1', '2']
denegados auditoria.leer: [None]
denegados contacto.cliente.leer: ['999', '27']
categorías de datos vistas: ['correo', 'nombre', 'telefono']
titulares distintos afectados: 30
```

Figura 6. *Resultado de la reconstrucción (horas de Chile).*

Tabla 14. Extracto de la línea de tiempo reconstruida (horas de Chile; se omiten los accesos intermedios del mismo tipo).

#	Hora	Actor	Operación	Recurso	Resultado	Origen	Detalle
66	03:07:12	—	auth.login	personal:2	fallido	181.43.77.0/24	clave_incorrecta

#	Hora	Actor	Operación	Recurso	Resultado	Origen	Detalle
67	03:07:37	—	auth.login	personal:2	fallido	181.43.77.0/24	clave_incorrecta
68	03:08:02	—	auth.login	personal:2	exito	181.43.77.0/24	—
70	03:08:20	personal:2	contacto.cliente.leer	1	permitido	181.43.77.0/24	—
72	03:08:38	personal:2	contacto.cliente.leer	2	permitido	181.43.77.0/24	—
73	03:08:56	personal:2	contacto.cliente.leer	3	permitido	181.43.77.0/24	—
99	03:16:20	personal:2	despacho.direccion.leer	1	denegado	181.43.77.0/24	—
100	03:16:50	personal:2	despacho.direccion.leer	2	denegado	181.43.77.0/24	—
101	03:17:20	personal:2	auditoria.leer	—	denegado	181.43.77.0/24	—
102	03:17:40	personal:2	contacto.cliente.leer	999	permitido	181.43.77.0/24	—
103	03:17:40	personal:2	contacto.cliente.leer	999	denegado	181.43.77.0/24	tras=102 motivo=regla_negocio
106	03:18:46	personal:2	contacto.invitado.leer	5	permitido	181.43.77.0/24	—
109	03:19:08	personal:2	contacto.invitado.leer	6	permitido	181.43.77.0/24	—
130	03:29:40	personal:2	contacto.cliente.leer	27	denegado	181.43.77.0/24	—



Reconstrucción del incidente INC-20261113-670B

Bitácora: íntegra (cadena HMAC y 6 anclas externas verificadas)

Actor	personal:2
Eventos en la ventana	39 (del 2026-11-13 06:07:12 al 2026-11-13 06:29:40 UTC)
Inicios de sesión	2026-11-13 06:07:12 · fallido · 181.43.77.0/24 (clave_incorrecta) 2026-11-13 06:07:37 · fallido · 181.43.77.0/24 (clave_incorrecta) 2026-11-13 06:08:02 · exito · 181.43.77.0/24
Redes de origen	181.43.77.0/24
Acceso a datos	2026-11-13 06:08:20 a 2026-11-13 06:19:08 UTC
Accesos efectivos · contacto.cliente.leer	26: 1, 2, 3, 4, 5, 6, 7, 8, 9, 10, 11, 12, 13, 14, 15, 16, 17, 18, 19, 20, 21, 22, 23, 24, 25, 26
Accesos efectivos · contacto.invitado.leer	4: 3, 4, 5, 6
Denegados · despacho.direccion.leer	1, 2
Denegados · auditoria.leer	sin recurso
Denegados · contacto.cliente.leer	999, 27
Categorías de datos vistas	correo, nombre, telefono
Titulares distintos	30

Estos valores alimentan la "Evaluación de alcance" del incidente. Los titulares se identifican solo por id interno.

Figura 7. *La misma reconstrucción en la web (/seguridad/incidentes/<código>/reconstruccion), con la línea de tiempo completa debajo.*

7.5 ¿Los registros permiten reconstruir lo ocurrido?

El script compara la reconstrucción con la verdad de terreno, punto por punto:

```
[OK] red de origen                                  ['181.43.77.0/24']
[OK] inicios de sesión fallidos                     2
[OK] contactos de clientes leídos                   26 ids
[OK] contactos de invitados leídos                  [3, 4, 5, 6]
[OK] intentos negados (incluye el id inexistente)     [('auditoria.leer', 'None'),
    ('contacto.cliente.leer', '27'), ('contacto.cliente.leer', '999'), ('despacho.direccion.leer',
    '1'), ('despacho.direccion.leer', '2')]
[OK] inicio del acceso a datos                      2026-11-13 06:08:20
[OK] fin del acceso a datos                         2026-11-13 06:19:08
[OK] la actividad legítima del jueves no se mezcla    ventana
Resultado: la bitácora reconstruye exactamente lo que hizo el atacante
```

Figura 8. *Comparación entre lo que hizo el atacante y lo que dice la bitácora.*

La bitácora responde todas las preguntas que necesita el plan: **quién** (la cuenta de Carla, desde una red que nunca había usado), **cuándo** (de 03:08:20 a 03:19:08), **qué** (correo, nombre y teléfono de 26 clientes y 4 invitados), **qué no** (ninguna dirección: los dos intentos fueron negados, y el cliente 999 no existía) y **cuántos** (30 titulares). Sin el evento de falla posterior de esta actividad, el intento sobre el cliente 999 habría aparecido como un acceso concedido. La actividad legítima de Carla del jueves no se mezcla, porque la ventana y la red la separan.

7.6 Evaluación, notificación y cierre

El alcance reconstruido alimenta directamente la evaluación del incidente. Como la aplicación descifró los datos para el atacante, eran legibles: hay riesgo razonable y se notifica a la **Agencia**. Correo, nombre y teléfono no son datos sensibles ni económicos, así que la ley no obliga a notificar a los titulares; el plan permite un aviso voluntario por el riesgo de phishing, que la delegada evalúa. El borrador sale del registro del incidente:

```
A la Agencia de Protección de Datos Personales:
1. Qué ocurrió: Acceso con la cuenta de una agente de soporte desde una red desconocida, fuera de
    horario, con lectura secuencial de contactos de clientes
2. Fecha de detección: 2026-11-13 06:27:00 (UTC). Período en que ocurrió: entre 2026-11-13
    06:08:20 y 2026-11-13 06:19:08.
3. Datos personales potencialmente afectados: correo, nombre, telefono. Titulares afectados
    (estimación): 30.
4. Posibles consecuencias: uso de los datos para correos o llamadas fraudulentas (phishing) y, si
    hubo credenciales, acceso no autorizado a la cuenta.
5. Medidas adoptadas: Cuenta de soporte deshabilitada y sus sesiones revocadas; Contraseña de la
    cuenta de soporte restablecida por el administrador; sesiones de todo el personal revocadas
    por precaución; Cuenta rehabilitada con la contraseña nueva.
6. Recomendaciones: cambie su contraseña de NortiShop y la de otros sitios donde use la misma;
    desconfíe de mensajes que pidan datos de pago o claves; NortiShop nunca le pedirá su
    contraseña.
7. Contacto para consultas y seguimiento: privacidad@nortishop.cl (indique el código
    INC-20261113-5F3F).
```

Figura 9. *Borrador de la notificación a la Agencia generado por el sistema.*

La erradicación usa la función nueva `restablecer_clave_personal`: el administrador fija una contraseña nueva, que Carla recibe por un canal aparte, y se revocan sus sesiones; además se revocan las del resto del personal por precaución. La contraseña filtrada deja de servir. `comprobar_recuperacion` confirma que la bitácora está íntegra, que no quedan permisos suspendidos ni alertas altas abiertas, y la cuenta se rehabilita. El incidente se cierra con sus lecciones: segundo factor obligatorio para el personal, restringir el acceso de soporte a la red de la oficina y la VPN, y capacitación sobre phishing.

Incidente `INC-20261113-670B`

Fase	**cerrado**
Tipo / severidad	credenciales_comprometidas · alta
Detectado	2026-11-13 06:27:00 UTC
Descripción	Acceso con la cuenta de una agente de soporte desde una red desconocida, fuera de horario, con lectura secuencial de contactos de clientes
Datos afectados	correo,nombre,telefono · titulares: 30
Notificar	Agencia: sí · titulares: no · notificado 2026-11-13 14:15:00
Medidas	Cuenta de soporte deshabilitada y sus sesiones revocadas Contraseña de la cuenta de soporte restablecida por el administrador; sesiones de todo el personal revocadas por precaución Cuenta rehabilitada con la contraseña nueva

Figura 10. *Registro del incidente cerrado: naturaleza, categorías, titulares, decisión de notificación y medidas (art. 14 sexies inc. 2).*

7.7 La bitácora no tiene los datos y no se puede recortar

```
130 datos personales ficticios buscados en 158 eventos -> encontrados: 0
¿contraseña de Carla en la bitácora? False
¿IP completa del atacante? False (solo se guarda la red /24)
en una copia se quitan el trigger y todas las filas desde el id 66 (el ataque y lo que siguió):
  verificar_cadena  -> ok=True (lo que queda es una cadena válida: recortar el final no la rompe)
  verificar_anclas  -> ok=False error_en=109 (el ancla externa de las 04:00 ya no existe)
```

Figura 11. *Comprobaciones finales del simulacro.*

La última prueba simula a un atacante con acceso al archivo de la base que quiere borrar sus huellas: en una copia quita el trigger y borra todas las filas desde el primer evento del ataque. `verificar_cadena` sigue diciendo que la cadena está bien, porque lo que queda es válido. Las anclas externas lo detectan: el registro 109, anclado a las 04:00 fuera de la base, ya no existe. Sin las anclas, este ataque a la bitácora habría pasado inadvertido.

8. Pruebas

`pruebas_actividad7.py` agrega 19 pruebas automatizadas sobre una base temporal. Con las de las actividades anteriores, el proyecto tiene 111 pruebas y todas pasan (evidencia/ev_act7_pruebas.txt). Cuatro pruebas anteriores se ajustaron a los cambios de esta actividad: el administrador ya no lee la bitácora (A05 y T23), `cuenta.registrar` pasó a la categoría `creacion` (A01), la API de la bitácora exige motivo (W03) y la prueba de purga usa un evento catalogado (A06).

Tabla 15. Pruebas de la Actividad 7.

Prueba	Qué comprueba
E01	Todo evento registrado está en el catálogo y tiene una categoría válida; un código inventado se rechaza; cada permiso tiene su evento
E02	Un detalle con un correo o un texto libre, o un correo como recurso, se reemplazan; el evento se conserva y la cadena sigue íntegra
E03	Una operación autorizada que la regla de negocio niega (o que falla por validación) deja un segundo evento con `tras=<id>`
E04	Se auditan la compra de invitado, la compra con cuenta, el pago rechazado, el cambio de estado, la retención y la analítica omitida
P01	El administrador no lee ni consulta la bitácora; su resumen no tiene actores ni recursos; otros roles no ven ni el resumen
P02	La consulta exige un motivo existente y se registra con el motivo y los nombres de los filtros, no sus valores
P03	Borrar el final de la bitácora no rompe la cadena, pero sí las anclas, y genera una alerta crítica; el archivo de anclas tiene permisos 600
P04	La evidencia de un incidente cerrado hace más de un año se elimina; la de uno reciente y el registro de ambos se conservan
P05	Las alertas descartadas de más de 2 años se purgan; las escaladas a incidente no
L01-L04	Cada alerta nueva se dispara con su condición y no en el caso normal (horario de atención, misma red, ids dispersos, soporte sin permiso)
L05	Una alerta alta avisa a la guardia sin la descripción; una media no
L06	Las ventanas se miden desde la fecha del evento: 5 fallos en 16 minutos no son fuerza bruta en 15
R01	La reconstrucción separa accesos efectivos de negados, da la red, las categorías y el titular, y solo la usa el rol seguridad
R02	Restablecer la contraseña revoca las sesiones, invalida la anterior, no deja la nueva en la bitácora y es solo del administrador
R03	API: filtros, fecha inválida (400), resumen para el administrador y 403 a su consulta completa
S01	El simulacro completo termina sin diferencias entre la reconstrucción y lo ocurrido

9. Limitaciones

- **Correo simulado.** El aviso a la guardia y las notificaciones usan el buzón en memoria de `notificador.py`; en producción irían por un proveedor de correo y SMS.

- **Anclas en el mismo servidor.** El archivo de anclas está fuera de la base, pero en la misma máquina. Su valor completo depende de enviarlo a otro servidor o a un almacenamiento de solo agregar, lo que es una tarea de despliegue.
- **Quien tiene la llave de auditoría.** Alguien con acceso al servidor y a `NORTISHOP_LLAVE_AUDITORIA` podría reescribir la cadena completa; las anclas externas lo limitan a lo posterior a la última ancla.
- **Red /24.** Guardar solo la red protege a las personas, pero dos usuarios de la misma red no se distinguen; para la regla de red nueva es suficiente.
- **Umbrales.** Los umbrales (8 ids consecutivos, horario de 08:00 a 21:00, 3 direcciones) son una primera calibración. Deben ajustarse con los falsos positivos reales en la revisión trimestral.
- **Alcance de la reconstrucción.** Reconstruye lo que pasó por la aplicación. Un acceso directo al archivo de la base, sin pasar por la aplicación, no deja eventos; para ese caso están los permisos del archivo, el cifrado y la evaluación con `datos_legibles` según si se comprometieron las llaves.

10. Referencias

[1] Ley N° 19.628, sobre protección de la vida privada, modificada por la Ley N° 21.719 (2024). Arts. 11, 14 quinquies, 14 sexies y 15 bis. Biblioteca del Congreso Nacional, idNorma 1209272.

[2] Ley N° 21.663, Ley Marco de Ciberseguridad (2024). Biblioteca del Congreso Nacional, idNorma 1202434.

[3] Reglamento (UE) 2016/679, Reglamento General de Protección de Datos, art. 33 (plazo de 72 horas, usado como referencia).

[4] NIST SP 800-61 Rev. 2, Computer Security Incident Handling Guide (fases del ciclo de respuesta).

[5] NIST SP 800-92, Guide to Computer Security Log Management (contenido, protección y conservación de registros).

[6] OWASP Logging Cheat Sheet (qué registrar y qué no registrar).

[7] Grupo 7, NortiShop: Actividades 1, 2, 4, 5 y 6 e informe de inventario y clasificación de datos personales. Repositorio github.com/m1lvn/nortishop-seguridad.

Anexo A. Cumplimiento de la pauta

Tabla 16. Dónde se cumple cada punto de la pauta.

Punto de la pauta	Sección del informe	Código y evidencia
1. Eventos auditados y campos de cada registro	2	`catalogo_eventos.py`, tabla `auditoria` (`db.py`), ev_act7_catalogo.txt
2. Registro de accesos y operaciones sin guardar los datos	3, 7.7	`auditoria.py`, `rbac.py`, `nortishop.py`; pruebas E01-E04; simulacro sección 9
3. Acceso restringido y plazo de conservación	4	`trazabilidad.py`, `rbac.py`, `auditoria.anclar`, `incidentes.purgar_evidencia`; pruebas P01-P05; Figuras 2 y 3
4. Al menos tres alertas propias y qué las dispara	5	`deteccion.py` (4 reglas nuevas); pruebas L01-L06
5. Plan: criterios, responsables, fases y contenido de la notificación	6	`incidentes.py`, `trazabilidad.reconstruir`
6. Simulacro y reconstrucción con los registros	7	`simulacro_act7.py`, ev_act7_simulacro.txt, ev_act7_reconstruccion.json; prueba S01; Figuras 4 a 11